

Tương quan giữa Nhân sự & Hệ thống AI

- Hồ sơ Nhân sự (HR files) và quá trình đào tạo bổ sung thêm dữ liệu cho AI.
- Xác định xem bộ phận tuyển dụng có thực sự quan tâm đến "Phân chia nhiệm vụ"(Separation of duties) khi tuyển dụng nhân tài để giảm thiểu rủi ro hay không.

- Nếu "Môi trường kiểm soát" tạo ra luật chơi, thì "Hoạt động kiểm soát" (Control Activities) là quá trình **giám sát hành vi thực tế** để tuân thủ luật đó.
- Công nghệ lõi hiện nay: **Khai phá Quy trình (Process Mining)**.

Data-Centric vs Metadata-Centric

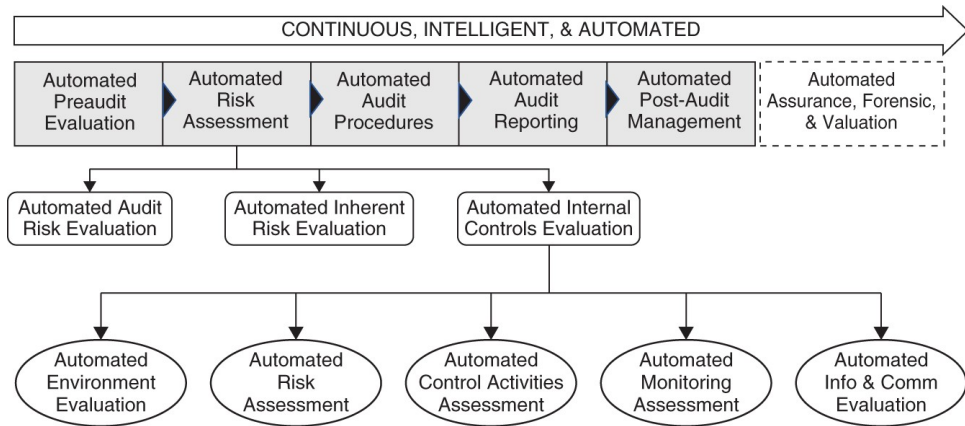
Phân loại	Kiểm toán truyền thống (Data-centric)	Process Mining (Metadata-centric)
Góc nhìn	Tập trung vào Dữ liệu Giao dịch.	Tập trung vào Siêu dữ liệu (Metadata).
Câu hỏi	Hóa đơn này trị giá bao nhiêu tiền? Giao dịch với ai?	Giao dịch đó để lại cái bóng gì trên hệ thống?
Kết quả	Tìm kiếm số tiền bị thất thoát.	Phát hiện lỗi hỏng quy trình vận hành.

Cái bóng Kỹ thuật số (Digital Shadow) là gì?

Siêu dữ liệu (Metadata) - Nhật ký sự kiện (Event Logs):

- Ai đã truy cập vào hệ thống?
- Đăng nhập từ địa chỉ IP nào?
- Thao tác đó được thực hiện vào mấy giờ, mấy phút (tính đến từng giây)?
- Process Mining gom hàng triệu dấu vết nhỏ này để tái tạo **toàn bộ đường đi thực tế** của dữ liệu!

Đánh giá Kiểm soát Nội bộ Tự động (Hình 9.1)



Hình: Mô hình Đánh giá Kiểm soát Nội bộ Tự động (COSO)

Bất kiêm nhiệm (Segregation of Duties) trong Lý thuyết

Quy tắc Kinh điển để Chống Tham ô

Nhân viên tạo một nhà cung cấp mới (Vendor) và người phê duyệt chuyển tiền cho nhà cung cấp đó **phải là hai người hoàn toàn khác nhau**.

Bất kiêm nhiệm trên Thực tế (Cách lách luật)

- Kẻ gian (một Kế toán trưởng) muốn tham ô, họ mượn tài khoản của cấp dưới để tự tạo "Nhà cung cấp ma".
- Sau đó dùng tài khoản của chính mình để Duyệt thanh toán cho "Nhà cung cấp ma" đó.
- Trên sổ sách (Data-centric): Giao dịch hoàn toàn hợp lệ, đủ 2 chữ ký điện tử, có đủ hóa đơn. Kiểm toán truyền thống sẽ bị qua mặt!

Case Study: 6 Phút của Gian lận

Đòn giáng của Process Mining

Thuật toán không quan tâm tờ hóa đơn. Nó quét Nhật ký hệ thống và nhận ra: Tài khoản Nhân viên A tạo vendor lúc **09:12 AM** từ **Địa chỉ IP 192.168.1.40**. Chỉ đúng **6 phút** sau, tài khoản Giám đốc B phê duyệt chuyển tiền từ **chính Địa chỉ IP 192.168.1.40** đó!

⇒ Cùng một máy tính, thực hiện 2 thao tác đối lập trong 6 phút. Cờ đỏ báo động ngay lập tức!

Bài toán Cảnh báo giả (False Positives)

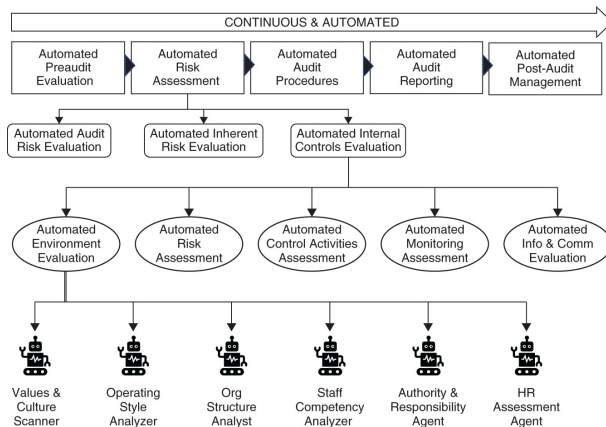
- Mọi cái click chuột, mọi lần đăng nhập muộn đều bị ghi lại.
- Nếu hệ thống Process Mining nguyên thủy cảnh báo bất cứ lúc nào có đăng nhập vào 2h sáng, nó sẽ tạo ra một **núi rác cảnh báo**.
- Kế toán viên sẽ kiệt sức vì những tiếng báo động giả (Alert Fatigue).

Cảnh báo giả: Khóa sổ lúc 2h sáng hay Gian lận?

- **Trường hợp 1:** Kế toán đăng nhập 2h sáng ngày 30/12 để làm quyết toán khóa sổ cuối năm. $\Rightarrow$ **Hợp lý.**
- **Trường hợp 2:** Kế toán đăng nhập 2h sáng ngày 14/03 để thay đổi Số tài khoản ngân hàng của một nhà cung cấp lớn. $\Rightarrow$ **Có mùi gian lận!**

- Dùng Machine Learning (Học máy) để hệ thống **tự học bớt ngu ngơ đi**.
- Cần sự can thiệp của Kế toán viên lão luyện (Human-in-the-loop).
- Chuyên gia sẽ "dán nhãn" cho AI: Dạy nó phân biệt đâu là áp lực khóa sổ bình thường, đâu là hành vi đánh cắp tài sản.

Đánh giá Môi trường Kiểm soát Tự động (Hình 9.2)



Hình: Đánh giá Môi trường Kiểm soát Tự động

Cây Gian lận (Fraud Tree của ACFE)

Dù công nghệ tối tân đến đâu, gian lận vẫn xảy ra vì đó là bản chất con người. Để AI bắt được kẻ gian, nó phải hiểu hình hài của chúng:

- ❶ Tham nhũng (Corruption)
- ❷ Chiếm đoạt tài sản (Asset Misappropriation)
- ❸ Gian lận Báo cáo Tài chính (Financial Statement Fraud)

Tam giác Gian lận vs Kim cương Gian lận

- **Tam giác gian lận truyền thống (Cressey):** Áp lực (Pressure), Cơ hội (Opportunity), Biện minh (Rationalization).
- **Kim cương gian lận (Fraud Diamond - Wolfe & Hermanson):** Trong doanh nghiệp hiện đại, 3 yếu tố trên là chưa đủ. Yếu tố thứ 4 quyết định tất cả chính là **Năng lực (Capability)**.

Phép ví von: Gian lận như một vụ cháy nổ

Hãy hình dung Kim cương gian lận chính là công thức tạo nên một vụ cháy nổ:

- **Áp lực:** Là "Chất đốt" (Nợ nần, thiếu tiền).
- **Cơ hội:** Là không gian đầy "Oxy" (Lỗ hổng hệ thống).
- **Biện minh:** Là "Nhiệt độ môi trường" (Tự nhủ: "Mình chỉ mượn tạm thôi").

Ba yếu tố trên tạo ra một căn phòng cực kỳ dễ nổ. Nhưng để vụ nổ thực sự xảy ra...